

2.2 Security Updates

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
<u>Control Definition</u> Control Objective: Minimise the occurrence of known technical vulnerabilities on operator PCs and within the user's Swift infrastructure by ensuring vendor support, applying mandatory software updates, and applying timely security updates aligned to the assessed risk. In-scope components: Hardware and all software running on the following systems, virtual machines, hosts, servers or devices: • physical systems or virtual machines (VMs) hosting a Swift-related component (including interface, GUI, Swift or customer (client) connector) • customer client connector • dedicated and general-purpose operator PC • jump server • on-premises or remote (that is hosted or operated by a third party, or both) virtualisation or cloud platform hosting Swift-related VMs, including those hosting the Alliance Connect Virtual on Premises VPN, and their management PCs • network devices protecting the secure zone or the customer client connectors • New HSM • bridging servers (such as middleware or file transfer servers other than customer connector) used for and guardian of the secure data exchange between back-office and Swift-related components Risk Drivers: • exploitation of known security vulnerabilities						
<u>Implementation Guidance</u> Control Statement: All hardware and software inside the secure zone and on operator PCs are within the support life cycle of the vendor, have been upgraded with mandatory software updates, and have had security updates promptly applied. Control Context: The closure of known security vulnerabilities is effective in reducing the various pathways that an attacker may use during an attack. A security update process that is comprehensive, repeatable, and implemented in a timely manner is necessary to continuously close these known vulnerabilities when security updates are available. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). • Vendor support – All software (including operating systems) and hardware (including network devices) are within the actively supported product life-cycle window of the vendor (including extended support), if applicable. – Maintenance or licensing contracts are in place for access to updates, minor upgrades, and other critical maintenance functions. • Mandatory software updates						

- Mandatory releases or updates that are applicable to a user's Swift component are installed within the deadline specified by the vendor.
- Application of security updates
 - A risk assessment process is in place to determine the most appropriate treatment of vendor security updates. Risk assessment considerations may include the vendor-reported criticality of the update, user exposure and vulnerability, mitigating controls, and operational impact.
 - User-defined deployment timelines are established for applying updates based on criticality, system type, and required update testing.
 - In the absence of established internal processes and timelines, Swift recommends the use of the Common Vulnerability Scoring System (CVSS) Version 3 or later as a guideline for criticality, with the following update deployment targets:
 - Critical (9.0+ score): applied within one month of release
 - High (7.0 – 8.9 score): applied within three months of release
 - Low / Medium (< 7.0 score): user defined
- Note:** It is common practice that operating system or application security updates are automatically pushed and applied on the Operator PCs shortly after their publication by the vendor or software provider.
- Source and integrity validation of software and security updates.
- Before applying the software and security updates, the legitimate source is validated and integrity checks (for example, checksum validation) are performed when technically possible.

Optional Enhancement:

- Apply the control to all bridging servers (such as middleware or file transfer servers other than customer connectors) used for data exchange between back-office and Swift-related components.